

AĞ VE SİSTEM GÜVENLİĞİNE GİRİŞ

Siber Saldırı ve Savunma Yöntemleri - Hafta 8



AĞ VE SİSTEM GÜVENLİĞİNE GİRİŞ

Bu ders kapsamında, ağ ve sistem güvenliğinin temel ilkeleri, kullanılan cihazlar ve mimariler detaylıca incelenecektir.

Ana konular:

- Ağ Güvenliği İlkeleri (CIA Üçlüsü)
- Ağ ve Sistem Güvenliği Cihazları (Firewall, IDS/IPS)
- Ağ Saldırı Türleri (Brute Force, SQL Injection, DoS/DDoS)
- İşletim Sistemi ve Sunucu Sıkılaştırma İlkeleri
- Donanım ve Kablosuz Ağ Güvenliği

AĞ GÜVENLİĞİ TANIMI VE SİBER TEHDİTLER

Ağ güvenliği, ağdaki verilerin, bilgilerin, ağ trafiğine dahil olan tüm cihazların ve dijital öğelerin izinsiz kullanım, yetkisiz erişim, imha veya değiştirme gibi zarar verici işlemlerden korunmasını ifade eder.

Siber saldırılar her geçen gün artmakta olup, bu saldırıların bir kısmı kullanıcıların bilgi eksikliğinden, bir kısmı da teknik kavram ve güvenlik ilkelerinin eksikliğinden kaynaklanmaktadır.

Ağ güvenliği, siber güvenliğin kritik bir unsurudur ve bireysel/kurumsal bilgilerin korunmasında büyük önem taşır.



AĞ GÜVENLİĞİNİN TEMEL İLKELERİ (CIA)

Tüm ağ güvenliği çözümleri, CIA (Confidentiality, Integrity, Availability) üçlüsüne uygun olmalıdır.

1. Erişilebilirlik (Availability): Yetkisi bulunan kişiler tarafından verilere ulaşılabilir olmasıdır. Yetkisiz erişim veya yetkililerin erişememesi sorun teşkil eder.
2. Gizlilik (Confidentiality): Verilerin, yetkisiz kişilere karşı korunmasıdır. Zararlı yazılımlar veya saldırılar sonucu gizliliğin ortadan kalkması büyük bir tehdittir.
3. Bütünlük (Integrity): Verinin isteyerek veya yanlışlıkla silinmesi/değiştirilmesi gibi eylemlerin önlenmesi. Bütünlüğün kaybolması, verinin doğruluk ve güvenliğinin kaybolması demektir.



AĞ GÜVENLİĞİ VE SİBER GÜVENLİK FARKI

Ağ güvenliği, bilgisayar ağını donanımsal ve yazılımsal yöntemler kullanarak korumayı amaç edinir. Bu, veri ve ağın gizliliğini ve erişilebilirliğini sağlar. Siber güvenlik, sistemi siber ve kötü niyetli saldırılardan korumak için alınan önlemlerin bütünüdür. Siber güvenlik, bilgisayar korsanının sisteme yetkisiz erişimini önlemek için sistemin güvenliğini artırmayı ve siber alanı saldırılara karşı korumayı amaçlar.



AĞI GÜVENLİ HALE GETİRME ADIMLARI I

Sistemi daha güvenli hale getirmek için atılması gereken öncelikli adımlar:

- Güçlü Parolalar Kullanmak: Parolaların karmaşıklığı, sisteme sızmak isteyenlerin işini zorlaştırır.
- Sistemin Güncel Kullanılmasını Sağlamak: Kullanılan sistemlerin güncel tutulması, birçok güvenlik açığının kapatılması ve zararlı yazılımlara karşı önlem alınması anlamına gelir.
- Antivirüs Kullanmak: Zararlı yazılımlardan korunmak için hem sunucu hem de istemci cihazlarda antivirüs çözümleri mutlaka kurulmalıdır. Yeni nesil antivirüs sistemler, IDS/IPS ve firewall sistemlerle entegre çalışır.



AĞI GÜVENLİ HALE GETİRME ADIMLARI II

- Güvenlik Duvarı Oluşturmak: Ağdan dışarı çıkacak veya içeri alınacak paketleri inceler. Doğru yapılandırma, ağ saldırılarını önlemede önemlidir.
- Yedek Almak: Belli zaman dilimlerinde verilerin yedeğini almak ve bu yedekleri farklı lokasyonlarda tutmak, erişilebilirlik ve güvenlik için temel ilkelerdendir.
- Yapılandırma Güvenliğini Sağlamak: Ağ cihazlarının doğru yapılandırılması gerekir. Yanlış yapılandırılmış bir cihaz, güvenlik zafiyeti oluşturur.



AĞI GÜVENLİ HALE GETİRME ADIMLARI III

- Log Yönetimi Sağlamak: Verilerin log yönetim sistemleri ile takip edilerek verilere kimlerin, ne zaman erişim sağladığının kayıt altına alınması ve raporlanması önemlidir.
- Güvenli Bağlantılar: İnternette güvenilir olmayan bağlantılardan kaçınılmalı, bilinmeyen web sitelerinde gezinmekten kaçınılmalıdır. Çalışanlara eğitim verilmesi en büyük önlemlerdendir.
- Sanal Özel Ağlar (VPN) Kullanmak: İnternet gibi daha az güvenli bir ağ üzerinden güvenli ve şifreli bağlantı oluşturan bir teknolojidir. Tüm veriler şifrelenir.
- Siber İstihbarat: Kurum için risk oluşturabilecek tehdit faktörlerini önceden analiz eden araçlar kullanmak.



AĞ VE SİSTEM GÜVENLİĞİ CİHAZLARINA GİRİŞ

Sisteme yetkisiz girişlerin önüne geçmek için kimlik doğrulama ve erişim kontrolü sağlayan cihazlar üretilmiştir.

- Saldırı Tespit Cihazları (IDS): 1984 yılında hizmete sunulan ilk güvenlik araçlarından. Normal olmayan trafiği tespit eder.
- Saldırı Önleme Cihazları (IPS): 1990'lı yılların sonlarına doğru üretilmiştir. Saldırıları tespit etmekle kalmaz, önlem de alabilir.
- Firewall Sistemleri: IDS/IPS başarısının ardından geliştirilmiştir. Çeşitli kuralların belirlenebildiği ve ağdan içeri giren/çıkan verilerin kontrol edilebildiği sistemlerdir (ilk paket filtreleme 1988).



ATAK ALGILAMA VE ÖNLEME CİHAZLARI

Ağ ve sistem güvenliğine yönelik atakları algılama ve önleme cihazlarından bazıları şunlardır:

- Firewall (Güvenlik Duvarı)
- Proxy
- DLP (Data Loss Prevention - Veri Kaybı Önleme)
- SIEM (Security Information and Event Management - Güvenlik Bilgileri ve Olay Yönetimi)
- IOC (Indicator of Compromise - Güvenlik Açığı Göstergesi)
- VAG (Virtual Air Gap - Sanal Hava Boşluğu)
- WAF (Web Application Firewall - Web Uygulaması Güvenlik Duvarı)

GÜVENLİK DUVARI (FIREWALL) TEMELLERİ

Firewall, ağa gelebilecek saldırıları önlemede kullanılan en yaygın cihazdır.

- Çalışma Mantığı: Belirli kuralların uygulanması, kural dışına çıkıldığında ise önlem alınması mantığı ile çalışır.
- Konum: OSI modelinin 3. (Ağ) ve 4. (iletim) katmanlarında çalışır. Yerel ağ ile geniş alan ağı arasında konumlandırılarak paketleri filtreler.
- Filtreleme Özellikleri: Port filtreleme, IP filtreleme, uygulama filtreleme, web filtreleme ve virüs imza tabanlı filtreleme gibi özelliklere sahiptir.

Firewall sistemler donanımsal ve yazılımsal olarak sınıflandırılır.

- Yazılımsal Firewall: Yazılım tanımlı ağ (SDN) mimarisi ile çalışabilir. Ağ trafiğini izler ve merkezî kontrolcüye sahiptir.
- Donanımsal Firewall: Özel donanımlar üzerinde çalışan sistemlerdir. Fiziksel olarak lokal ağ sistemi veya bulut üzerine konumlandırılabilir.
- Kurallar Dizini: Firewall'da hazırlanan kurallar dizinine White List (Beyaz Liste) adı verilir. Bu listede olmayan bütün bağlantı istekleri bloke edilir.

STATEFUL VE STATELESS FIREWALL'LAR

1. Stateful (Durum Bilgisine Sahip) Firewall:

- Anlık olarak trafiği işleyebildiği için sahte mesaj ve yetkisiz erişimi engelleme noktasında başarılıdır.
- Bağlantının durumunu (state) takip eder.

2. Stateless (Durum Bilgisine Sahip Olmayan) Firewall:

- Erişim listeleri (ACL) hazırlanarak paketlerin giriş ve çıkışları kontrol edilir.
- Anlık durum bilgisine sahip olmadığı için trafik hızlı akabilir, ancak güvenlik düzeyi Stateful cihazlara göre daha zayıftır.

YENİ NESİL GÜVENLİK DUVARI (NGFW)

Yeni Nesil Güvenlik Duvarı (Next Generation Firewall - NGFW), gelişen saldırı yöntemlerine karşı üretilmiştir.

- Özellikler: Performanstan ödün vermeden paket içeriğini, kaynak-hedef ve kullanıcı davranışlarını kontrol edebilir.
- Uygulama Tanıma: NGFW'yi geleneksel mimariden ayıran en önemli fark, trafiği oluşturan uygulamaları tanıyabilmesidir.
- DPI: Veri paketlerinin çok detaylı incelenebilmesi (Deep Packet Inspection) sayesinde ikinci bir üründe kontrole gerek kalmaz, bu da maliyeti ve gecikmeyi düşürür.

DİĞER ÖNEMLİ FIREWALL TÜRLERİ

1. Ağ Adresi Çevirisi Güvenlik Duvarı (NAT):

- Dâhilî cihazların tek bir IP adresi üzerinden ağ bağlantısı sunmasını sağlar.
- İç ağdaki IP adreslerinin gizliliğini korur ve IP adresi üzerinden saldırı yapmayı düşünen hackerlara karşı koruma sağlar.

2. Bütünleşik Güvenlik Duvarı (UTM):

- Çeşitli güvenlik önlemlerini (saldırı koruma, içerik/mail filtreleme, casus sistem tespiti) tek bir cihaz altında birleştirir.
- Merkezî kontrol sağlama ve maliyet avantajı sunar.

AĞ GÜVENLİK MİMARİLERİNE GİRİŞ

Ağ güvenlik mimarileri, ağda bulunan cihaz ve kullanıcıların, hizmet veren servis ve uygulamaların, ağı yöneten güvenlik ekipmanlarının ilke ve politikalarına verilen isimdir.

- Asıl amaç: Güvenliği tehdit eden durumlarla başa çıkabilmek ve ağın performanslı bir şekilde çalışmasını sağlamaktır.
- Tasarım İlkeleri: Dış ağa hizmet verecek servisler farklı güvenlik seviyelerinde denetim altına alınmalıdır. Ağa giren ve çıkan bütün paketlerin kontrol edildiği bir izleme sistemi hazırlanmalıdır.

MİMARİ ELEMANLARI: AKTİF VE PASİF BİLEŞENLER

Ağ güvenliği mimarilerini oluşturan araçlar aktif ve pasif ağ güvenliği bileşenleri olarak sınıflandırılır.

- Aktif Cihazlar (Fonksiyonel): Anahtarlama cihazı, yönlendirici, firewall, NIC kartı, gateway.
- Pasif Cihazlar (Yapısal): Kabinet, kanal, priz, kablo, patch panel.
- Anahtarlama Cihazları (Switch): OSI 2. katmanda çalışır (günümüzde 3-7 katman arası da mevcuttur). VLAN, port güvenliği ve erişim denetimi gibi güvenlik teknolojilerini tümleşik kullanır.

MİMARİDE YÖNLENDİRİCİ VE GÜVENLİK DUVARI

Yönlendirici (Router): Bir ağ topolojisinde dış ortama bakan en önemli cihazdır ve saldırıya en çok uğrayan cihazdır. Gelen paketlerin yönlendirilip hedefe ulaşmasından sorumludur.

Güvenlik Duvarı (Firewall): Ağ trafiğini güvenli bir şekilde kontrol etmek amacıyla mimarilere eklenir. İçten dışa veya dıştan içe gelen trafiği kontrol ederek istenmeyen paketleri engeller.



SİLAHSIZLANDIRILMIŞ ALAN (DMZ)

Silahsızlandırılmış Alan (DMZ): Gerek iç ağı gerekse dış dünyaya hizmet veren sunucuların konumlandırıldığı bölgedir.

- Güvenlik Seviyesi: DMZ'deki güvenlik önlemleri iç ağı göre daha azdır.
- Konumlanan Servisler: Genellikle web, uygulama ve e-posta sunucuları bu bölgede yer alır.
- Kritik Veri Konumu: Özel ve kritik öneme sahip veriler, herkese açık bilgilerin bulunduğu DMZ'lerin arkasına konumlandırılmalıdır.



IDS/IPS VE VPN CİHAZLARININ MİMARİDEKİ YERİ

Saldırı Tespit Sistemleri (IDS): Ağa yapılan saldırıları tespit edip kayıt altına almak ve sistem yöneticisine uyarıda bulunmak amacıyla kullanılır.

Saldırı Önleme Sistemleri (IPS): Saldırı tespiti ve önleme işlemlerini birlikte gerçekleştirir.

Konumlandırma: IDS/IPS sistemleri; yönlendirici ve güvenlik duvarı arasında, güvenlik duvarı ve iç ağ arasında veya birden çok arayüzü dinleyecek şekilde konumlandırılabilir.

VPN Cihazları: IPSec, PPTP, L2TP gibi güvenlik protokollerini kullanan donanımsal ve yazılımsal cihazlardır ve aktif eleman olarak konumlandırılır.



MİMARİ MODELLERİ: SANAL YEREL AĞ (VLAN) KULLANIMI

VLAN, yerel alan ağlarındaki kaynakları ve ağ kullanıcılarını gruplandırır (muhasabe, insan kaynakları, üretim vb.).

- İzolasyon: Farklı görev ve işlerde çalışan kullanıcıların ağ trafiği birbirinden izole edilerek ağ performansı artırılır ve güvenlik sağlanır.
- Yönetim Kolaylığı: Departman değişikliği yapan personelin ağ değişikliği yapmasına gerek kalmaz, bu da BT departmanının iş yükünü azaltır.
- Güvenlik Artışı: Hassas verilere sahip firmalar, bu verilerin bulunduğu ağı izole ederek güvenliğini en üst seviyeye çıkarır.

TEK GÜVENLİK DUVARI MİMARİLERİ

Ağ güvenliği mimarilerinde Silahsızlandırılmış Alan (DMZ) olması veya olmaması durumuna göre iki farklı mimari kullanılır.

1. DMZ Kullanılmayan Model: İç ağda sunucu olmaması gerekir. Eğer sunucu varsa hem yerel hem de dış ağdan gelen saldırılara açıktır. Dış ağdan iç ağa erişime izin verilmemesi gerekir.
2. İki veya Daha Fazla DMZ Bölgesi Olan Model: Bir yönlendirici ve bir güvenlik duvarının bulunduğu, çeşitli güvenlik seviyelerinin konumlandırıldığı mimaridir. Güvenlik duvarı WAN, LAN ve DMZ ağlarını birbirine bağlar.

İKİ GÜVENLİK DUVARI MİMARİSİ

Ağ güvenliğinin çok önemli olduğu topolojilerde iki veya daha fazla güvenlik duvarı kullanılan mimariler tercih edilir.

- Amaç: Yetkisiz bir kullanıcının veya saldırganın bir güvenlik duvarını aşması durumunda diğer güvenlik duvarının devreye girmesi istenir.
- Risk Azaltma: İki firewall, güvenlik duvarları içine yerleştirilmiş bir arka kapı veya güvenlik açığının tüm sistemi etkileme riskini azaltır.
- Esneklik: İki güvenlik duvarının birbirine bağlanması, çok sayıda DMZ bölgesi oluşturmayı ve her bölgede farklı güvenlik seviyesi elde etmeyi sağlar.



AĞ SALDIRI TÜRLERİNE GENEL BAKIŞ

Ağ saldırıları, yerel ağdaki istemci ve sunucu bilgisayarları ile ağ cihazlarını devre dışı bırakmak, verileri ele geçirmek veya yetkisiz erişim sağlamak için gerçekleştirilir.

1. Pasif Ağ Saldırıları: Saldırganlar ağı yetkisizce izleyebilir, verileri görüntüleyebilir veya ele geçirebilir; ancak silemez veya erişilebilirliği engelleyemez (Örn: Ağ dinleme).
2. Aktif Ağ Saldırıları: Yetkisiz erişim sağlayan saldırgan, ağdaki veri bütünlüğünü bozar ve ağın işleyişine zarar verir (Örn: Parola kırma, DoS).

PAROLA KIRMA SALDIRILARI

Parola kırma, saldırganın zayıf parola kullanımı veya hatalı yapılandırmalar sonucu ağa yetkisiz erişim sağlamasıdır.

- Çevrimiçi Saldırıları: Brute Force, geçerli parolayı bulmak adına bilinen veya özel araçlarla hazırlanmış listeleri deneme yanılma yöntemiyle hedef sistemde dener.

- Çevrimdışı Saldırıları: Hash Crack ve Rainbow Table saldırıları. Sistemin tuttuğu şifre hash bilgilerini elde etmeye ve kırmaya yöneliktir.

Örnek araç: Hydra, kaba kuvvet saldırıları uygulamak için kullanılır.

HİZMET REDDİ SALDIRILARI (DOS/DDOS)

Hizmet Reddi (DoS): Bir hedefe yönelik yapılan, verilen hizmeti engelleme veya kullanıcıların sisteme erişmesini engelleme amacı taşıyan saldırılardır.

Sistemin kapasitesini aşarak hizmet veremez hale gelmesini sağlar.

Dağıtık Hizmet Reddi (DDoS): Hizmet sunan sistemlere kaldırabileceği kapasitenin çok üstünde istek göndererek sistem kaynaklarını tüketmeyi amaçlar.

- Zombi Bilgisayarlar: DDoS'ta kullanılan, sistemlerine yüklenen zararlı yazılımlar ile haberleri dahi olmadan saldırılara katılan istemci bilgisayarlardır. IoT cihazlarının artması saldırıların popülerliğini artırmıştır.



SQL INJECTION SALDIRILARI

SQL Injection (SQLi), veri tabanında SQL sorgularına yetkisiz müdahale edilerek sistemin kandırılmasına dayanan saldırılardır. OWASP TOP 10 içinde yer alan tehlikeli saldırılardandır.

Saldırı Türleri:

1. In-Band (Bant İçi): HTTP Post ve Get isteklerinin aynı iletişim yolu üzerinden gönderilip alındığı tekniktir (Error Based ve Union Based).
2. Blind (Kör) SQL Injection: Saldırgan, sunucunun yanıt ve davranışlarını gözlemleyerek veri tabanı hakkında bilgiye ulaşır, ancak sorgu sonucunu göremez.
3. Out of Band (Bant Dışı): Bilgileri toplamak için aynı iletişim kanalını kullanmaz.



ORTADAKİ ADAM SALDIRILARI (MITM) VE ÇEŞİTLERİ

Man in The Middle (MITM), iletişim halindeki iki bilgisayarın arasına girerek ağı dinleyen, verileri okuyan veya manipüle eden bir saldırı türüdür. MITM ile parola, kişisel veriler, kredi kartı bilgileri gibi kritik bilgiler ele geçirilebilir.

Çeşitli MITM saldırı türleri:

- ARP Spoofing (ARP sahtekârlığı)
- DNS Spoofing (DNS sahtekârlığı)
- DHCP Spoofing (DHCP sahtekârlığı)
- Rogue Access Point (Sahte erişim noktası)

İŞLETİM SİSTEMİ GÜVENLİK İLKELERİNE GİRİŞ

İşletim sistemleri, diğer uygulama ve servislere güvenlik altyapısı sağladığı için güvenliği, bütün sistemin güvenliği için büyük rol oynar.

Varsayılan güvenlik uygulamaları herkes tarafından bilindiği için, sistem yöneticileri güvenlik politikaları belirlemeli ve sıkılaştırma yapmalıdır.

Güvenlik Yapılandırmalarına Örnekler:

- Kullanıcı gruplarını, hesaplarını ve parolalarını sınırlandırmak
- Gereksiz hizmetleri devre dışı bırakmak
- Güvenlik duvarı etkinleştirmeleri ve tarayıcı sıkılaştırmaları

Varsayılan kullanıcı bilgileri, yetkisiz erişim sağlayacak kişinin ilk deneyeyeceği yöntemdir.

Önlemler:

- Varsayılan kullanıcı isimlerini değiştirmek veya devre dışı bırakmak.
- Yönetici hesabını farklı bir kullanıcı adı ile oluşturmak.
- Yeni kullanıcılara minimum yetkiler verilerek hesap oluşturmak (En Az Yetki Prensibi).
- Veri tabanı ve web uygulamaları için çalışan servislerin varsayılan isimlerini değiştirmek.



İşletim sistemlerinde parola güvenliği kritik bir yapılandırmadır. Varsayılan parolalar güvenlik açığı oluşturur.

NSA (Ulusal Güvenlik Ajansı) Standartlarına göre önerilenler:

- Maksimum şifre süresi: 42 gün
- Minimum şifre süresi: 2 gün
- Minimum şifre uzunluğu: 12 karakter
- Şifre geçmişini zorlama: 5 şifre

Şifreler hem güvenli hem de karmaşıklığı belli bir sisteme dayanan şekilde üretilmelidir.



HESAP KİLİTLEME POLİTİKALARI

- Yerel güvenlik ilkeleri ile hesap kilitleme yapılandırmaları yapmak mümkündür.
- Bu politikalar, bir kullanıcının hesap kilitlenmeden önce kaç kez oturum açmaya çalışabileceğini ve hesabın ne kadar süreyle kilitleneceğini belirler.
 - Bu ayarlar, parola saldırılarına karşı alınabilecek bir önlemdir.
 - Dikkat: Uygun yapılandırılmadığında, DoS/DDoS saldırıları gerçekleştirilebileceği için dikkatli yapılmalıdır.

KAYIT DEFTERİ VE GÜVENLİK ŞABLONLARI

Kayıt Defteri (Registry): İşletim sisteminde ayarları ve seçenekleri depolamak için kullanılan bir veri tabanıdır. Kayıt defterinde değişiklik yapmadan önce yedek alınmalıdır.

– Boş oturumlar (Anonim Bağlantılar): Paylaşımlardan yararlanılabilecek önemli bir zayıflıktır ve anonim erişim kayıt defteri ayarları kapatılmalıdır.

Güvenlik Şablonları: İşletim sistemi sıkılaştırmasını basitleştirir ve yüzlerce olası ayar içerir. Yöneticilerin, bu ayarları Grup İlkesi Nesneleri (GPO) aracılığıyla merkezî olarak dağıtmasını sağlar.



SUNUCU SİSTEMLERİ GÜVENLİK İLKELERİ

Sunucu sistemleri güvenlik ilkeleri, kurulum aşamasından başlayarak büyük bir hassasiyet ile uygulanmalıdır, aksi takdirde geri dönüşü olmayan kayıplar yaşanabilir.

Kurulum Önlemleri:

- Sunucunun kurulumu ağdan ayrı veya izole bir ağda yapılmalıdır.
- Yalnızca doğrulanmış medya aygıtları kullanılmalı ve indirilen dosyaların bütünlüğü doğrulanmalıdır.
- Kötü amaçlı yazılımdan koruma sistemleri ve güvenlik duvarları en kısa zamanda kurulmalı ve yapılandırılmalıdır.



Sıkılaştırma Önlemleri:

- Dosya Sistemi İzinleri: Her veri klasörüne yalnızca bu bilgilere erişim için gerekli izin düzeyine sahip kişilerin erişimine izin verilmelidir.
- NTP Senkronizasyonu: Tüm sunucular, olayların birbiriyle ilişkilendirilmesi için bir Ağ Zaman Protokolü (NTP) sunucusu ile senkronize edilmelidir.
- Pasif Hesaplar: Kullanılmayan veya gereksiz kullanıcı hesapları devre dışı bırakılmalı veya silinmelidir, suistimal riskini ortadan kaldırır.



ROL TABANLI ERİŞİM KONTROLÜ (RBAC)

RBAC, kuruluş bünyesindeki kullanıcılara, rollerine ve sorumluluklarına uygun şekilde erişim izni vermek için kullanılan bir yapıdır.

- Avantajları: Gelişmiş Güvenlik Kontrolü, Verimli Kullanım (sistem yönetimi kolaylaşır), Denetim Kolaylığı, Ölçeklenebilirlik (yeni rol ekleme/değiştirme imkanı).
- Uygulama Adımları: Roller tanımlanır, izinler belirlenir, kullanıcılara roller atanır, roller ve izinler eşlenir, sistem düzenli gözden geçirilir ve güncellenir.

AĞ CİHAZLARININ SIKILAŞTIRILMASI

Ağ sıkılaştırma, bir siber güvenlik altyapısındaki güvenlik açıklarını en aza indirme sürecidir.

Sıkılaştırma, şu riskleri azaltır:

- Ağ cihazlarının hatalı yapılandırmasından kaynaklı açıklar.
- Ağda çalışan fakat gerekli olmayan sistemlerin sağladığı açıklar.

İyi bir ağ sıkılaştırma politikası için:

- Ağ haritalandırılmalı ve belgelendirilmelidir.
- Güvenlik açıkları tespit edilmeli ve düzeltilmelidir.



Telnet, bir cihaza uzaktan bağlanmak için kullanılan, sunucu-istemci protokolüdür (23 numaralı port).

- Avantajı: Ağ yöneticileri için pratik bir uzaktan yönetim protokolüdür ve neredeyse tüm cihazlar tarafından desteklenir.
- Yüksek Güvenlik Riski: Telnet bağlantıları şifrelenmez (Clear Text). Uzaktan erişim için gerekli oturum açma bilgileri de dahil olmak üzere gönderilen tüm bilgiler, ağ izleme yazılımları aracılığı ile düz metin olarak ele geçirilebilir.
- Güvenli Alternatif: Secure Shell (SSH).



SECURE SHELL (SSH) PROTOKOLÜ

SSH (Secure Shell), iki ağ cihazının iletişim kurmasını ve verileri paylaşmasını sağlayan, güvenli bir ağ iletişim protokolüdür.

- Güvenlik: İki ağ cihazı arasındaki iletişimin şifrlenmesi sağlanır.
- Kullanım: Uzaktaki bilgisayarlarda oturum açmak, komutları yürütmek ve dosya transferi için yaygın kullanılır.
- Port: Varsayılan olarak standart TCP bağlantı noktası 22'yi kullanır.
- Şifreleme Yöntemleri: SSH, simetrik şifreleme (AES, 3DES, Diffie-Hellman), asimetrik şifreleme (RSA, DSA) ve hashleme yöntemlerini kullanır.

SSH SIKILAŞTIRMA VE GÜVENLİK İLKELERİ

SSH bağlantılarının güvenliğini artırmak için yapılması gerekenler:

- Root ile SSH bağlantıları devre dışı bırakılmalıdır.
- SSH versiyon 1 yerine daha güvenli olan versiyon 2 kullanılmalıdır.
- Bağlantı boştayken kullanım süresi ayarlanmalıdır (Timeout değeri).
- SSH bağlantısını kullanacak kişiler sınırlandırılmalıdır.
- Şifre denemeleri sınırlandırılarak kaba kuvvet saldırıları engellenmelidir.
- 22 numaralı varsayılan TCP portu değiştirilmelidir.
- İki faktörlü kimlik doğrulama ve SSH anahtarı kimlik doğrulaması aktifleştirilmelidir.

AĞ CİHAZI YAPILANDIRMA KONTROLLERİ

Ağ cihazlarında (switch, router vb.) veri kaybının ve ihlallerinin önüne geçmek için yapılandırma aşamasında sıkılaştırma yöntemleri uygulanmalıdır.

Önemli sıkılaştırmalar:

- Parolalar açık metin olarak görünmemeli, MD5 algoritması ile kriptolanmalıdır.
- Kimlik doğrulama için AAA (Authentication, Authorization, Accounting) sunucusu kullanılmalıdır.
- Cihaz yönetimleri belirlenmiş IP'ler üzerinden yapılmalıdır.
- Sistem günlükleri tutulmalı ve Telnet yerine SSH kullanılmalıdır.
- SNMP erişimi kısıtlanmalıdır.



DONANIM GÜVENLİĞİ İLKELERİ

Bilişim teknolojileri sistemlerinin güvenliği, fiziksel ve fiziksel olmayan güvenlik olarak ikiye ayrılır.

Fiziksel Güvenlik Tehditleri:

- İç Tehditler: Hatalı sistem odası kurulumu, yangın, elektrik arızaları, nem, sıcaklık.
- Dış Tehditler: Yıldırım, deprem, sel.
- İnsan Faktörü: Yetkilendirilmemiş personelin sisteme girişi, hatalı cihaz yapılandırmaları, hırsızlık, donanımların talimat dışı kullanımı.



SİSTEM ODASI STANDARTLARI (ISO 27001)

Donanımların fiziksel güvenliğini sağlamada ISO:27001 standartları kullanılmalıdır.

- Ortam Isısı ve Nemi: Sistem odalarının 15 °C ile 25 °C ısı aralığında olması, nem düzeyinin ise %40 ile %75 arasında tutulması gerekir.
- Su Kontrolü: Su tahliye alanlarının bulunması, yükseltilmiş döşeme ve nem uyarı sistemlerinin olması korumayı artırır.
- Deprem: Cihazların sabit kalabilmesi için rack kabinlerin yere, tavana ve kendi aralarında sabitlenmesi sağlanmalıdır.



Enerji kontrolü, olası kaçak akımlar ve kesintilere karşı UPS (Kesintisiz Güç Kaynağı) sistemlerinin kurulmasını içerir.

- Kritik donanımların en az iki adet uygun kapasiteli, paralel çalışan UPS'den beslenmesi ve UPS'lere ayrı trafodan enerji verilmesi sağlanmalıdır.
- Topraklama uygun yapılmalı ve statik elektriğe karşı önlemler alınmalıdır.
- Kablolama: Manyetik alan oluşumu sonucu veri kayıplarını minimize etmek için enerji ve ağ kabloları ayrı kanallardan yapılmalıdır. Kablolar anlaşılır şekilde etiketlenmelidir.



KABLOSUZ AĞLARA GİRİŞ VE TEMEL KAVRAMLAR

Kablosuz ağ (Wireless Network), bilgisayar ve ağ cihazları arasında kablo kullanılmadan radyo sinyalleri (RF) kullanılarak oluşturulan ağ çeşididir.

- Menzil: Radyo sinyalleri 300 metreye kadar gönderilebilir ve metal olmayan duvarlardan geçebilir.
- Haberleşme Şekilleri: Radyo dalgaları ile haberleşme; alıcı (receiver), verici (transmitter) ve alıcı/verici (trans-receiver) olmak üzere üç şekilde gerçekleşir.



KABLOSUZ AĞ BAĞLANTI ÇEŞİTLERİ

1. Wi-Fi: Günümüzün en çok bilinen kablosuz ağ teknolojisidir. Cihazların kablosuz olarak birbirine bağlanmasını sağlar.
2. Bluetooth: Kısa mesafelerde ses ve veri iletimini sağlamak için oluşturulmuştur (10 metreye kadar). 2.4 GHz hızında iletişim kurar.
3. Kızılötesi (IRDA): Birkaç metreyi aşmayan kısa uzaklıklar için kullanılır. 1-4 Mbps veri iletişim hızındadır.
4. Uydu: Dünya yörüngesindeki uyduların mikrodalga istasyonu olarak kullanılmasıdır. Genellikle diğer altyapıların bulunmadığı yerlerde tercih edilir.

Farklı firmaların cihazlarının sorunsuz iletişim kurabilmesi için IEEE 802.11 standartları geliştirilmiştir.

- 802.11a (1999): 5 GHz bandı, 54 Mbps bant genişliği.
- 802.11b (1999): 2.4 GHz bandı, 11 Mbps bant genişliği. Kapalı alanda 30-45 metre kapsama.
- 802.11g (2003): 2.4 GHz, maksimum 54 Mbps bant genişliği.
- 802.11n (2007): 2.4 GHz veya 5 GHz, 540 Mbps bant genişliği. 125 metreye kadar kapsama.



Yanlış güvenlik protokolü seçimi, riskli bağlantılara yol açabilir.

1. WEP (Wired Equivalent Privacy): Kablosuz ağlar için kabul edilen ilk güvenlik protokolüdür (1999). Çok fazla güvenlik açığı vardır ve şifreler kısa sürede kırılabilir. Günümüzde kullanımı tavsiye edilmez.
2. WPA (Wi-Fi Protected Access): WEP'in açıklarını kapatarak geliştirilmiştir (2003). TKIP (Geçici Anahtar Bütünlüğü Protokolü) kullanır.

3. WPA2 (Wi-Fi Protected Access 2): WPA'nın yerini almıştır (2004). AES (Gelişmiş Şifreleme Standardı) algoritmasını zorunlu kılar ve CCMP protokolünü kullanır.

4. WPA3: WPA2'deki zafiyetler sebebiyle geliştirilmiştir. 192 bit şifreleme tekniği getirir, zayıf şifre kullanımını engeller ve kaba kuvvet saldırılarına karşı koruma sağlar. Ayrıca açık şebekelerde kullanıcı gizliliğini güçlendirir.

KABLOSUZ AĞ TÜRLERİ

IEEE standartlarına göre kablosuz ağlar dört ana türe ayrılır:

- Kablosuz Kişisel Alan Ağları (WPAN): Kısa mesafeli, düşük güçlü vericiler kullanır (6-9 metre). Bluetooth yaygın kullanılır.
- Kablosuz Yerel Alan Ağı (WLAN): Orta büyüklükte bir ağı kapsar (95 metreye kadar). Ev ve ofis ortamlarında kullanılır.
- Kablosuz Şehir Alan Ağı (WMAN): Daha geniş coğrafi alan üzerinde hizmet verir (Şehir veya belirli bir bölge).
- Kablosuz Geniş Alan Ağları (WWAN): Ulusal ve küresel iletişim için uygundur, en geniş coğrafi alanda kapsama sağlar.

KABLOSUZ AĞ ÇALIŞMA MODLARI

IEEE 802.11 standardında iki farklı çalışma modu bulunur:

1. Cihazdan Cihaza Çalışma Modu (Ad-Hoc Mode): İki veya daha fazla bilgisayarın arada Access Point (AP) olmadan direkt bağlandığı yapılardır. Hızlı kurulum sağlar ancak güvenlik açısından dezavantajlıdır.
2. Altyapı Çalışma Modeli (Client-Server): Ağ ortamında bulunan cihazların iletişim kurabilmesi için merkezî bir AP cihazına ihtiyaç duyulur. İletişim, AP aracılığıyla WEP veya WPA gibi protokollerle şifrelenir.

KABLOSUZ AĞA BAĞLANMA AŞAMALARI

Cihazların kablosuz ağ ortamına bağlanabilmesi için iki aşama gereklidir:

1. Kimlik Doğrulama (Authentication): Kullanıcının kimlik bilgilerinin yetkili kullanıcıların veri tabanındaki kimlik bilgileriyle eşleşip eşleşmediği kontrol edilir. İki çeşidi vardır: Açık Sistem (MAC adresi isteği) ve Parola (ortak parola kullanımı) Kimlik Doğrulama.
2. Ağa Kaydolma (Association): Kimlik doğrulama bittikten sonra istemci cihaz, AP tarafından ağa kaydedilir. Ağa kaydolmayan bir cihaz iletişimde bulunamaz.

KABLOSUZ AĞ KARTI ÇALIŞMA MODLARI

Kablosuz ağ adaptörleri, sürücü ve işleve bağlı olarak dört farklı modda çalışabilir:

- Master Modu (Hostap): Kablosuz ağda hizmet veren sunucu modudur (Erişim Noktası).
- Managed Modu: İstemci bilgisayarların bir erişim noktasına bağlanarak hizmet aldığı moddur.
- Monitör Modu: Herhangi bir ağa bağlanmadan, pasif olarak ilgili kanaldaki tüm trafiğin izlenmesine olanak sağlayan moddur. Kablosuz ağlarda güvenlik konusunda sık kullanılır.
- Ad-Hoc Modu: Arada bir AP olmaksızın kablosuz istemcilerin haberleşmesi için kullanılır.

KABLOSUZ AĞ KEŞİF YÖNTEMLERİ

Kablosuz ağların keşfi, yakın çevredeki internet erişim noktalarının bulunmasıdır.

- Wardriving: Keşif araçlarını taşınabilir hale getirerek etrafta bulunan kablosuz ağları keşfetme işlemidir.
- Aktif Keşif: Çeşitli programlar kullanılarak açık yayın yapan AP'leri tespit etme. AP cihazına sinyal gönderilerek kendini anons etmesi istenir.
- Pasif Keşif: AP cihazından izin almadan gizli bir şekilde dinleme yapma veya trafik analizi olabilir. Kismet, Wireshark, airodump-ng gibi araçlar kullanılır.

KABLOSUZ AĞ GÜVENLİK ZAFİYETLERİNE GİRİŞ

Kablosuz iletişimin hava ortamında yapılması, kablolu ağlardaki risklere ek olarak yeni zafiyetleri ortaya çıkarır.

Başlıca zafiyetler şunlardır:

- Ağ trafiğinin dinlenmesi ve zayıf şifrelemenin çözülmesi (parolalar, e-postalar açığa çıkabilir).
- Sahte kablosuz ağ oluşturma (Rogue Access Point).
- Ağ topolojisinin ortaya çıkarılması.
- Veri kaybı veya manipülasyonu.
- IP numaralarının yasal olmayan işlerde kullanılması (ARP Spoofing).
- Hizmetin aksatılması.

EL SIKIŞMA (HANDSHAKE) YAKALAMA VE ŞİFRE KIRMA

Handshake (El Sıkışma), cihazın Access Point'e tekrar bağlanmaya çalışırken gönderdiği kritik veri paketidir.

- Deauthentication Saldırısı: Saldırgan, aireplay-ng gibi araçlar kullanarak hedeflenen istemci cihazın bağlantısını sonlandırır.
- Paket Yakalama: Bu kesinti üzerine cihaz tekrar bağlanmaya çalışırken oluşan Handshake paketi yakalanır (CAP dosyası olarak kaydedilir).
- Şifre Çözümleme: Yakalanan CAP dosyası, aircrack-ng aracı kullanılarak bir kelime listesi (dictionary/rockyou.txt) ile karşılaştırılarak şifre kırılmaya çalışılır.

SAHTE KABLOSUZ AĞ (ROGUE AP) OLUŞTURMA

Yetkisiz kişiler, kendi cihazlarını bir erişim noktasına dönüştürerek ortama sahte erişim noktaları ekleyebilirler.

- Amaç: Bu sahte ağa (Ör: BEDAVAWIFI) bağlanan kullanıcıların internet trafiğini ve aktivitelerini izlemektir.
- Uygulama: Saldırganlar, DHCP servisini yapılandırarak sahte ağa bağlanan cihazlara IP aralığı verir ve iptables ayarları ile trafiği yönlendirir.
- Veri Ele Geçirme: Sahte AP üzerinden bağlanan cihazların hangi sitelere gittiği izlenebilir veya dnscf/tcpdump ile parola bilgileri elde edilebilir.

ARP PROTOKOLÜ VE ARP SPOOFING

ARP (Adres Çözümleme Protokolü), IP adresi bilinen bir bilgisayarın MAC adresini öğrenmeye yarar.

ARP Spoofing (ARP Zehirlemesi) saldırısı, saldırganın ARP tablosunu manipüle ederek:

- Ağdaki hassas verileri çalmasına olanak tanır.
- İletişim halindeki cihazların, trafiklerini saldırganın bilgisayarı üzerinden geçirmesini sağlar (MITM türü bir saldırıdır).
- Bu sayede saldırgan, ağ trafiğini izleyebilir (Wireshark).

KABLOSUZ AĞ GÜVENLİĞİNİ SAĞLAMA

Güvenli bir kablosuz ağ oluşturmak için bireysel ve kurumsal önlemler alınmalıdır.

1. Aygıt Yazılımlarını Güncelleme: Güvenlik açıklarını onarmak için kablosuz ağ cihazları (router) periyodik olarak güncellenmelidir.
2. Yönetici İşlemleri: Uzaktan erişim devre dışı bırakılmalı, yönetici işlemleri ethernet kablosu ile yapılmalıdır.
3. Varsayılan Ayarları Değiştirme: Varsayılan kullanıcı adları, şifreler ve ana bilgisayar adları değiştirilmelidir. Güçlü ve karmaşık parolalar kullanılmalıdır.
4. HTTPS Kullanma: Web sitesinden gönderilen/alınan verilerin şifrelenmesini sağlar.



KRİTİK GÜVENLİK YAPILANDIRMALARI

1. SSID Yönetimi: Servis Seti Tanımlayıcısı (SSID) değiştirilmelidir; varsayılan isim, bilgisayar korsanlarının router türünü öğrenmesine yol açabilir.
2. WPS Ayarları: WPS (Wi-Fi Protected Setup) devre dışı bırakılmalıdır, çünkü WPA2 ile çalışan routerların en büyük güvenlik açıklarından biridir.
3. Şifreleme Standardı: WPA2 şifrelemesi kullanılmalıdır. WEP gibi eski ve zayıf şifrelemeler kolayca kırılabilir.
4. AES Şifreleme: Routerın tek güvenlik protokolü olarak AES (Advanced Encryption Standart) seçilmelidir. AES/TKIP seçeneği ideal değildir.
5. Erişim Cihazının Yeri: Sinyal mesafesinin dışarıdaki kişilerin erişimini zorlaştırması için ayarlamalar manuel olarak yapılabilir.



İstenmeyen durumların tespiti için Kablosuz Ağ Saldırı Tespit Sistemleri (WIDS) geliştirilmiştir.

1. WIDS (Wireless IDS): Ağdaki erişim noktalarının doğrulanmasını, güvenlik sorunları olan noktaların belirlenmesini ve AP'lere yönelik saldırıların tespit edilmesini sağlar. Örnek araç: Kali Linux'ta bulunan Kismet.
2. WIPS (Wireless IPS): Bir radyo spektrumunu izleyerek ve olağandışı ağ etkinliği arayarak yetkisiz ağ erişimini önler. Hileli erişim noktalarını (Rogue AP), ortadaki adam veya hizmet reddi saldırılarını önlemeye yardımcı olabilir. Örnek yazılımlar: Snort, Suricata, Bro (Zeek).

AĞ VE SİSTEM GÜVENLİĞİNE GİRİŞ

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

